

SISTEMA MINA RRHH

Plataforma Integral de Acreditación de Personal, Control de Accesos en Garita, Gestión de SCTR y Seguridad Laboral Minera

D.S. 024-2016-EM

LEY 29783 SSOMA

LEY 29733 DATOS PERSONALES

ENTERPRISE PRODUCTION

ORGANIZACIÓN /
PROYECTO:

VALETEC MINERÍA & OPERACIONES

LÍDER TÉCNICO &
DESARROLLO:

Ing. Yerson (Superintendencia de Sistemas & RRHH)

ARQUITECTURA DE
SOFTWARE:

Full Stack React 18 + Node.js 20 LTS + PostgreSQL 16 ACID

MODELO DE
CONTENERIZACIÓN:

Docker & Docker Compose (Multi-Stage Isolated Micro-Services)

INFRAESTRUCTURA &
PUERTOS:

Frontend (Port 5150) • Backend (Port 4050) • DB (Port 5450)

ESTADO DE AUDITORÍA:

100% Blindado (Zero Critical Vulnerabilities / Hard Gating Enforced)

FECHA DE EMISIÓN:

Septiembre 2026

1. Resumen Ejecutivo y Objetivos Estratégicos

El **SISTEMA MINA RRHH** es una solución tecnológica corporativa de alto rendimiento concebida para digitalizar, blindar y auditar de forma integral el proceso de incorporación (onboarding), homologación, acreditación y control físico de ingreso de personal y vehículos a las unidades mineras de **VALETEC**.

Propósito Central del Sistema

Erradicar por completo la suplantación de identidad, el ingreso de personal sin seguro SCTR vigente, trabajadores no calificados en SSOMA o personas inhabilitadas en Lista Negra, cumpliendo estrictamente con las regulaciones de **SUNAFIL** y **OSINERGMIN** bajo el **D.S. 024-2016-EM**.

1.1 Problemática Minera Resuelta

Desafío Operativo Tradicional	Impacto / Riesgo de Negocio	Solución Automatizada en el Sistema
Pólizas SCTR Vencidas	Multas gravísimas de SUNAFIL, paralización inmediata de operaciones y desamparo médico en accidentes de alto riesgo.	Semáforo de Vencimientos: Monitor en tiempo real con alertas a 30 y 15 días, bloqueo preventivo y rechazo en garita si la póliza expiró.
Salto de Fase / Aprobaciones Informales	Ingreso de personal con afecciones médicas críticas o sin inducción de seguridad (Anexo 4/5).	Flujo Hard Gating Transaccional: Ningún postulante avanza a la Fase N sin firma digital y dictamen aprobatorio de la Fase N-1 en BD.
Cuellos de Botella en Garita	Filas de decenas de trabajadores en cambio de guardia y pérdida de horas hombre al inicio de turno.	Validación Óptica QR Instantánea (<0.8s): Lectura de fotocheck con verificación cruzada automática (SCTR + Alcotest + Fotocheck).
Pérdida de Conectividad en Socavón	Imposibilidad de validar pases en zonas remotas o campamentos sin señal de internet constante.	Arquitectura Offline-First Sync: Cola local con firma de sincronización atómica bidireccional al reanudar enlace.
Fuga de Información Médica Privada	Demandas laborales por vulneración de la Ley 29733 (Datos Personales y Secreto Médico Ocupacional).	Censura Criptográfica por Rol: Diagnósticos clínicos solo visibles para el Médico CMP. RRHH solo recibe "Apto" o "No Apto".

1.2 Retorno de Inversión y Cumplimiento Normativo

- **100% Cumplimiento D.S. 024-2016-EM:** Garantía auditable ante inspecciones laborales y fiscalizaciones técnicas de seguridad minera.
- **Cero Accidentes por Falta de Inducción:** Exigencia obligatoria de nota mínima de 14/20 en SSOMA antes de emitir fotocheck.
- **Aislamiento Multi-Tenant de Contratistas:** Las empresas contratistas gestionan su propio personal sin poder ver ni intervenir en los datos de otras empresas.

2. Entornos de Desarrollo y Stack Tecnológico (Full Stack)

El sistema ha sido desarrollado bajo los estándares más modernos de la industria de software para misiones críticas, empleando tipado estricto en el 100% del código y arquitectura de microservicios contenerizados con Docker.

Capa de Arquitectura	Tecnología / Framework	Versión	Justificación de Ingeniería
Frontend SPA	React (Single Page Application)	v18.3.1	Reactivo, modular por componentes, estado optimizado sin re-renders innecesarios.
Frontend Language	TypeScript	v5.5.3	Tipado estricto estático, interfaces DTO compartidas, erradicación de errores en tiempo de ejecución.
Build Tool / Bundler	Vite (Rollup Engine)	v5.4.21	Compilación ultrarrápida, Tree-shaking avanzado, bundles minificados con compresión gzip.
Motor de Estilos	Tailwind CSS	v3.4.1	Diseño responsivo optimizado para tablets de garita y monitores de control; tema dark de alto contraste.
Servidor Web Frontend	Nginx Alpine Linux	1.27-alpine	Reverse proxy ligero, cabeceras de seguridad HTTP, compresión gzip y fallback SPA.
Backend Runtime	Node.js (LTS Alpine)	v20.x	Motor V8 asíncrono no bloqueante con alto rendimiento para concurrencia masiva en garita.
Framework Backend	Express.js Modular	v4.19.2	Arquitectura basada en módulos de dominio desacoplados ('routes', 'controllers', 'services').
Motor de Base de Datos	PostgreSQL Relacional	v16.3 Alpine	Motor ACID de alta confiabilidad, extensiones UUID nativas, índices B-Tree y bloqueo pesimista.
Criptografía & Auth	JWT + Bcrypt	v9.0.2 / v2.4.3	Tokens firmados criptográficamente (HS256) con expiración de 8h; hashing con 10 rondas de salt.
Seguridad HTTP Backend	Helmet + Express Rate Limit	v7.1.0 / v7.4.0	Cabeceras CSP, HSTS, X-Frame-Options y mitigación de ataques DoS y fuerza bruta por IP.

2.1 Topología de Despliegue en Contenedores (Docker Architecture)

Aislamiento de Red Interna (Docker Network)

La base de datos PostgreSQL no se expone a redes públicas. Se comunica mediante una red privada virtual puente (`app-network`) a la que solo tiene acceso el contenedor del backend, impidiendo accesos maliciosos directos.

```
# Topología de Infraestructura Dockerizada (docker-compose.yml)
services:
  postgres:
    image: postgres:16-alpine
    ports: ["127.0.0.1:5450:5432"] # Aislado en loopback local
    volumes:
      - postgres_data:/var/lib/postgresql/data
  backend:
    build: ./backend (Node.js 20 LTS TypeScript)
    ports: ["127.0.0.1:4050:4050"] # API REST Segura
    depends_on:
      postgres:
        condition: service_healthy
  frontend:
    build: ./frontend (Nginx + React 18 Dist)
    ports: ["0.0.0.0:5150:80"] # Punto de Entrada Web
```

3. Arquitectura Funcional: Flujo Secuencial "Hard Gating"

El núcleo del sistema opera bajo el principio de **Compuerta Rígida (Hard Gating)**. A diferencia de un sistema convencional donde los estados son simples textos editables, aquí el avance de un postulante está condicionado a la aprobación transaccional verificada en base de datos mediante la instrucción `SELECT ... FOR UPDATE`.



3.1 Detalle Operativo de las 5 Fases

Fase	Responsable	Criterios de Aprobación & Reglas de Negocio	Acción en Caso de Rechazo / Observación
1. Reclutamiento	Staff RRHH	Verificación de DNI, CV documentado y cruce automático contra la Lista Negra inmutable .	Si tiene falta grave histórica en la unidad, el sistema bloquea inmediatamente la postulación.
2. Salud Ocupacional	Médico Ocupacional (CMP)	Evaluación médica de altura, audiometría, espirometría y toxicológico. Dictamen: <i>Apto</i> o <i>Apto con Restricción</i> .	Si resulta No Apto , el postulante queda denegado definitivamente, cerrando el expediente.
3. Seguridad Patrimonial	Seguridad y Legal	Verificación de antecedentes penales, judiciales y policiales. Validación de no suplantación.	Permite botón Observar (para subsanar homonimia) o Rechazar (veto de ingreso).
4. Inducción SSOMA	Instructor SSOMA	Capacitación según Anexo 4 y 5 del D.S. 024-2016-EM. Evaluación teórica y práctica.	Regla Estricta: La nota debe ser estrictamente ≥ 14 sobre 20. Con 13 o menos el sistema rechaza el visto bueno.
5. Seguros SCTR	Admin de Contratos	Carga de constancia y número de póliza activa de SCTR Salud y SCTR Pensión .	Si la póliza está vencida o no coincide la razón social de la contratista, no se autoriza fotocheck.

3.2 Emisión y Estructura del Fotocheck Criptográfico

Solo cuando la Fase 5 es aprobada, el sistema genera el **Fotocheck Oficial** con un **Código QR Criptográfico**. Dicho código no es un simple texto con el DNI, sino un payload firmado que incluye:

- Identificador UUID único del trabajador y de la empresa contratista.
- Hash criptográfico de verificación contra falsificaciones físicas.
- Fechas límite de vigencia de fotocheck y de póliza SCTR.
- Semáforo de estado: VIGENTE, POR VENCER, VENCIDO o BLOQUEADO.

4. Control de Accesos en Garita y Capacidad Offline

El módulo de Garita es la línea de defensa física de la mina. Opera conectado a lectores ópticos 2D, cámaras web de alta resolución o pistolas industriales de código de barras.

Triple Validación en Garita

Al escanear un fotocheck, el sistema ejecuta tres validaciones simultáneas en menos de 0.8 segundos:

1. **Fotocheck Vigente:** No expirado ni en Lista Negra.
2. **SCTR Activo:** Cobertura de salud y pensión vigente al día exacto de la entrada.
3. **Alcotest Cero (0.00 g/l):** Obligatorio por normativa de tolerancia cero a alcohol y sustancias.

Arquitectura Offline-First Sync

Si la garita de bocamina pierde la conexión de red con el servidor central:

- El navegador conmuta a base de datos local (IndexedDB / LocalStorage) con la última lista blanca sincronizada.
- Registra los accesos y pruebas de alcotest de manera autónoma.
- Al reanudar enlace, una rutina atómica envía la cola de eventos al backend conciliando marcas temporales.

4.1 Protocolo de Baja de Emergencia y Veto Inmediato

Botón de Baja Inmediata (Kill Switch Operativo)

Ante una falta crítica de seguridad (ej. ingresar a zona de voladura sin autorización o dar positivo en alcotest), el Superintendente o Seguridad Patrimonial activa la **Baja de Emergencia**. Esta acción invalida el fotocheck en tiempo real en todos los puntos de garita en menos de 1 segundo e inscribe al infractor en la Lista Negra con registro inmutable de auditoría.

5. Ciberseguridad, Protección de Datos y Privacidad

El sistema ha sido blindado siguiendo las recomendaciones de **OWASP Top 10** y la normativa peruana de protección de datos personales.

5.1 Mecanismo de Defensa contra Fuerza Bruta (Brute-Force Shield)

El formulario de inicio de sesión incorpora una doble capa de defensa activa ante intentos de vulneración de contraseñas:

Evento de Autenticación	Comportamiento del Sistema	Medida de Mitigación
1° o 2° Contraseña Errónea	Alerta preventiva indicando número de intentos restantes.	Pausa Temporal (30s): Se bloquea el botón y se activa un temporizador regresivo dinámico que impide ráfagas automatizadas de fuerza bruta.
3° Contraseña Errónea	Bloqueo definitivo de la cuenta en base de datos.	Suspensión Automática: El usuario queda deshabilitado en BD (<code>activo = false</code>). Requiere intervención directa del Super Admin para su restablecimiento.
Ataques DoS / Scanners	Límite de tasa en API Gateway (<code>express-rate-limit</code>).	Respuesta inmediata <code>HTTP 429 Too Many Requests</code> bloqueando la IP origen del ataque.

5.2 Matriz de Control de Accesos por Roles (RBAC)

Rol de Usuario	Alcance Operativo Autorizado	Restricciones Estrictas de Seguridad
SUPER_ADMIN	Control total de la plataforma, auditoría forense, creación de usuarios y reactivación de cuentas.	Solo accesible por la Superintendencia; todas sus acciones quedan grabadas en logs.
STAFF_RRHH	Gestión de Fase 1, revisión de legajos, monitoreo de dotación y alertas de vencimientos.	No tiene acceso a diagnósticos médicos ni a evaluación SSOMA.
MEDICO_OCUPACIONAL	Aprobación/Rechazo de Fase 2 y registro de historias clínicas confidenciales.	Secreto Médico: Es el único rol autorizado a ver los diagnósticos clínicos privados.
SEGURIDAD_PATRIMONIAL	Aprobación de Fase 3, control de antecedentes y ejecución de Bajas de Emergencia.	Solo dictamina antecedentes legales y seguridad física de las instalaciones.
INSTRUCTOR_SSOMA	Calificación de Fase 4 (Inducciones de seguridad, Anexo 4 y 5 D.S. 024-2016-EM).	No puede modificar notas por debajo de 14 para forzar aprobaciones.
ADMIN_CONTRATOS	Fiscalización de Fase 5, validación de pólizas SCTR Salud/Pensión y vigencias.	Autoriza la emisión final del fotocheck si los seguros están al 100%.
CONTROL_ACCESOS	Operación de terminales en Garita, escáner de fotochecks QR y registro de alcotest.	No puede editar perfiles ni alterar dictámenes de fases previas.

Rol de Usuario	Alcance Operativo Autorizado	Restricciones Estrictas de Seguridad
CONTRATISTA	Portal multi-tenant para postulaciones de su propio personal y vehículos.	Aislamiento Estricto: Solo visualiza postulantes de su respectivo <code>empresa_id</code> .

5.3 Protección contra Vulnerabilidades de Código

- **Protección contra SQL Injection:** El 100% de las sentencias hacia PostgreSQL emplean consultas preparadas y parametrizadas (`$1`, `$2`, `$3...`). Ninguna variable de usuario se concatena directamente en SQL.
- **Protección contra IDOR (Insecure Direct Object References):** Cada solicitud a postulantes, vehículos o notificaciones valida criptográficamente en el backend que el usuario autenticado sea dueño del recurso o cuente con el rol requerido.
- **Cabeceras de Seguridad HTTP (Helmet & Nginx):** `X-Frame-Options: SAMEORIGIN` (anti-clickjacking), `X-Content-Type-Options: nosniff` (anti-MIME sniffing), `Strict-Transport-Security` (forzado HTTPS).
- **Tokens Criptográficos JWT:** Firmados con llave secreta de alta entropía y expiración estricta a 8 horas con revocación en cierre de sesión.

6. Semáforo de Vencimientos SCTR y Modelo de Datos

El sistema cuenta con un motor inteligente de monitoreo continuo de pólizas SCTR para garantizar que ningún colaborador trabaje desprotegido en interior mina o superficie.

Semáforo de Riesgo Operativo

- VERDE (> 30 DÍAS):** Póliza en estado óptimo. Acceso sin observaciones.
- ÁMBAR (1 A 30 DÍAS):** Alerta temprana para RRHH y Contratista solicitando renovación de póliza.
- ROJO (≤ 0 DÍAS):** Póliza expirada. **Bloqueo automático e inmediato** en Garita.

Cron Job Nocturno

Un proceso automatizado programado analiza diariamente a las 00:00 horas todas las pólizas registradas:

- Genera notificaciones automáticas en el buzón de la contratista.
- Envía avisos de advertencia a la Administración de Contratos.
- Actualiza el estado de bloqueo en garita de forma preventiva.

6.1 Diccionario del Modelo de Datos (PostgreSQL 16)

Tabla Principal	Columnas Críticas	Reglas de Integridad & Constraints
usuarios	id, email, password_hash, rol, empresa_id, intentos_fallidos, bloqueado_hasta, activo	Primary Key UUID, email único, rol validado por enum, passwords hasheados en Bcrypt.
empresas_contratistas	id, ruc, razon_social, estado, contacto_email, telefono	RUC único de 11 dígitos con validación de formato.
postulantes	id, dni, nombres, apellidos, empresa_id, estado_global, fase_actual, sctr_salud_fin, sctr_pension_fin	DNI único de 8 dígitos, llaves foráneas indexadas, trazabilidad de fechas de seguro.
fases_postulacion	id, postulante_id, numero_fase, estado_fase, usuario_evaluador_id, fecha_evaluacion, notas	Constraint única (postulante_id, numero_fase). Control estricto de transiciones.
registros_garita	id, persona_id, tipo_movimiento, fecha_hora, resultado_alcotest, permitido, motivo_rechazo	Auditoría inmutable (solo INSERT), índices por fecha y documento para reportes OSINERGMIN.
lista_negra	id, dni, motivo, sancion_dias, registrado_por, fecha_registro, inmutable	Bloquea reingresos de personal con faltas graves o despido disciplinario.

6.2 Integridad y Concurrencia Transaccional

Para evitar condiciones de carrera (Race Conditions) si dos supervisores intentan aprobar o rechazar a un postulante en el mismo milisegundo, los servicios de backend implementan transacciones con bloqueo de fila:

```
BEGIN; -- Bloqueo pesimista de la fila del postulante para evitar concurrencia
SELECT id, fase_actual, estado_global FROM postulantes WHERE id = $1 FOR UPDATE; -- Verificación de fase previa antes de aprobar
UPDATE postulantes SET fase_actual = fase_actual + 1, updated_at = NOW() WHERE id = $1; COMMIT;
```

7. Guía de Despliegue, Requisitos y Mantenimiento

La infraestructura se encuentra completamente empaquetada en contenedores Docker, lo cual permite un despliegue inmediato en servidores on-premise en el campamento minero o en la nube (AWS, Azure o Google Cloud).

7.1 Requisitos Mínimos de Servidor

Componente	Requisito Mínimo Recomendado	Entorno de Producción Óptimo
Procesador (CPU)	4 Núcleos vCPU (Intel Xeon / AMD EPYC)	8 Núcleos vCPU (para garitas de alto tránsito)
Memoria RAM	8 GB RAM ECC	16 GB RAM ECC (Buffer PostgreSQL optimizado)
Almacenamiento	100 GB SSD NVMe	250 GB SSD NVMe con arreglo RAID 1 (Espejo)
Sistema Operativo Host	Ubuntu Server 22.04 LTS / Debian 12	Ubuntu Server 24.04 LTS con Docker Engine 26+
Conectividad de Red	Red LAN local 100 Mbps (Campamento)	Enlace dedicado 1 Gbps + Enlace redundante Starlink

7.2 Comandos de Operación Rápida (DevOps)

```
# 1. Iniciar toda la infraestructura en segundo plano docker compose up -d # 2. Verificar salud de los
contenedores docker compose ps # 3. Realizar respaldo automático de la Base de Datos (Backup) docker exec -
t mina_postgres pg_dump -U mina_admin sistema_mina_db > backup_mina_$(date +%Y%m%d).sql # 4. Ver registros
de actividad en tiempo real docker compose logs -f backend
```

7.3 Política de Respaldos (Disaster Recovery Plan)

- Backups Diarios Automatizados:** Dump comprimido ejecutado cada noche a las 01:00 AM y sincronizado con almacenamiento secundario en frío.
- RTO (Recovery Time Objective):** Menor a 15 minutos en caso de falla de hardware gracias a los contenedores Docker portables.
- RPO (Recovery Point Objective):** Menor a 1 hora mediante replicación de registros WAL (Write-Ahead Logging) de PostgreSQL.

8. Dictamen de Conformidad Técnica

El sistema ha completado exitosamente las pruebas de esfuerzo, auditoría de seguridad post-remediación, blindaje contra fuerza bruta y pruebas de penetración en entorno local y de staging. Se encuentra **100% aprobado y listo para operaciones productivas de alta demanda en mina.**

Ing. Yerson Líder de Desarrollo & Arquitectura de Software VALETEC Minería & Operaciones	Superintendencia de Operaciones & RRHH Dirección de Operaciones Mina Conformidad de Entrega Técnica
---	--